MF0488_3 –GESTIÓN DE INCIDENTES DE SEGURIDAD INFORMÁTICA

1. Sistemas de Detección y Prevención de Intrusiones (IDS/IPS)
2. Implantación y Puesta en Producción de Sistemas IDS/IPS
3. Control de Código Malicioso
4. Respuesta ante Incidentes de Seguridad
5. Proceso de Notificación y Gestión de Intentos de Intrusión
6. Análisis Forense Informático

Módulo 1 Sistemas de Detección y Prevención de Intrusiones (IDS/IPS)

Objetivos:

Analizar los fundamentos conceptuales, tecnológicos y operativos de los sistemas de Detección y Prevención de Intrusiones (IDS/IPS). Identificando sus tipos, arquitecturas y criterios de implantación segura, en el contexto de la Gestión de Incidentes de Seguridad Informática.

Contenido:

1. Conceptos generales de Gestión de Incidentes, Detección de Intrusiones y su prevención
2. Identificación y caracterización de los datos de funcionamiento del Sistema
3. Arquitecturas más frecuentes de los Sistemas de Detección de Intrusos
4. Relación de los distintos tipos de IDS/IPS por ubicación y funcionalidad
5. Criterios de Seguridad para el establecimiento de la ubicación de los IDS/IPS

1. Conceptos generales de Gestión de Incidentes, Detección de Intrusiones y su prevención

- La **Gestión de Incidentes de Seguridad** constituye un proceso estructurado destinado a identificar, contener, mitigar y aprender de dichos sucesos.

- Un **Incidente de Seguridad** es cualquier evento que compromete o amenaza con comprometer la Confidencialidad, Integridad o Disponibilidad de los Sistemas de Información

- El proceso de Gestión de Incidentes no solo implica una respuesta técnica eficaz, sino también una planificación estratégica que permita reducir el impacto de los incidentes, minimizar los tiempos de interrupción y reforzar la postura de seguridad de la organización.

- La **Gestión de Incidentes** se incluye en un enfoque de gobernanza de la ciberseguridad que incluye políticas, procedimientos y controles técnicos y organizativos.

Ciclo de vida de un Incidente:

1. **Identificación**: Se detecta el evento y se evalúa si constituye realmente un Incidente de Seguridad
2. **Contención**: Se aplican medidas para evitar que el incidente se extienda y afecte a otros sistemas
3. **Erradicación**: Se eliminan los componentes del ataque
4. **Recuperación**: Se restauran los Sistemas afectados a un estado seguro y funcional
5. **Lecciones aprendidas**: Se documenta el Incidente, se analizan sus causas y se revisan los procedimientos para evitar futuras recurrencias.

Equipo de Respuesta ante Incidentes (CSIRT):

- En entornos organizativos profesionales, la respuesta a los Incidentes es gestionada por equipos especializados conocidos como Computer Security Incident Response Teams (CSIRT)

- Su misión es coordinar la respuesta técnica y comunicativa, generar inteligencia sobre amenazas, proponer mejoras y actuar como enlace con organismos nacionales e internacionales (INCIBE-CERT)

INCIBE-CERT_ Respuesta a incidentes

- La Gestión de Incidentes constituye el marco estructurado de respuesta ante eventos de seguridad que afectan a la información y los sistemas. Sus fases (identificación, erradicación, recuperación y lecciones aprendidas) permiten actuar de manera eficaz y controlada.

Equipos especializados como los CSIRT desempeñan un papel esencial en entornos complejos, facilitando la coordinación y la mejora continua.

- **Incidente de Seguridad**: Evento que compromete o puede comprometer la Seguridad de los Sistemas
- **Fases de Gestión de Incidentes**: Identificación, contención, erradicación, recuperación, lecciones aprendidas
- **Objetivo de la Gestión**: Minimizar impacto, recuperar operaciones, mejorar la postura de seguridad
- **CSIRT**: Equipos especializados en responder y coordinar la Gestión Técnica de Incidentes.

¿Qué son y para qué sirven los SIEM, IDS e IPS?
¿Qué es un WAF?
¿Qué es el pentesting? Auditando la seguridad de tus sistemas
¿Qué es OWASP? ¿Qué es el OWASP Top 10?
Mejores Herramientas Gratuitas de Informática Forense
16 Mejores Herramientas para Pruebas de Penetración (Pentest)
Herramienta Lansweeper
Herramienta Spiceworks
Herramienta Nessus
Herramienta Nmap-Zenmap
Herramienta Ansible
Herramienta Puppet

Clasificación de Intrusiones

- **Intrusión**: Cualquier acceso, uso o manipulación no autorizada de un Sistema, Red o Servicio Informático.

Estos accesos pueden tener fines maliciosos, o meramente exploratorios, pero en todo caso supone una violación de las políticas de seguridad y confidencialidad, por lo que es necesario catalogar correctamente las intrusiones.

El Objetivo del Atacante

- **Robo de información**: se accede a datos confidenciales
- **Interrupción del Servicio**: Ataques de denegación de servicios
- **Control del Sistema**: integrarlo en redes bots, difundir malware o lanzar nuevos ataques

Nivel de Complejidad y Técnica empleada

- **Intrusiones automatizadas**: Realizadas por bots o scripts sin interacción humana
- **Intrusiones dirigidas**: ataques manuales, planificados, buscan un objetivo común

El Tipo de Vector de Ataque

- **Intrusiones Físicas**: acceso no autorizado a dispositivos o servidores
- **Intrusiones Remotas**: Explotación de vulnerabilidades desde redes externas
- **Intrusiones Internas**: Originadas por usuarios con acceso legítimo

El Momento en que se detecta

- **Intrusiones en tiempo real**: son descubiertas durante su ejecución
- **Intrusiones Diferidas**: son identificadas a posteriori, al revisar registros o tras observar consecuencias

Principios de Detección

- Detectar Intrusiones de forma eficaz implica aplicar diversos principios técnicos y metodológicos que permitan identificar comportamientos anómalos o patrones conocidos de ataque. Los Sistemas IDS/IPS se basan en estos principios.

- **Detección basada en firmas (signatura-based detection)**

  Esta técnica compara el tráfico de red o los eventos del sistema con una base de datos de patrones conocidos de ataque. Es eficaz para detectar amenazas previamente identificadas.

- **Detección basada en anomalías (anomaly-based detection)**

  Se define un comportamiento considerado normal para el sistema y se detectan desviaciones respecto a ese perfil. Es útil para descubrir ataques novedosos o comportamientos inusuales.

- **Enfoque híbrido**: Actualmente muchos sistemas combinan ambas técnicas. Primero filtran el tráfico con firmas conocidas, y luego aplican reglas de anomalías para eventos dudosos o no reconocidos.

Detección basada en firmas

Ventajas

- Alta precisión frente a ataques conocidos
- Baja tasa de falsos positivos en entornos estables

Limitaciones

- No detecta amenazas nuevas o variantes no registradas
- Requiere actualización constante de la base de firmas

Detección basada en anomalías

Ventajas

- Capacidad de detectar amenazas desconocidas (zero-day)
- Adaptación a entornos dinámicos y usuarios legítimos maliciosos

Limitaciones

- Mayor tasa de falsos positivos
- Requiere entrenamiento previo del Sistema y ajuste fino

Consideraciones sobre la eficiencia de la detección

La eficacia de un Sistema de Detección no depende únicamente del motor que utilice, sino también de factores como:

- La ubicación del Sistema IDS/IPS dentro de la arquitectura de red
- La Capacidad de Procesamiento y rendimiento ante volúmenes altos de tráfico
- La Frecuencia y Calidad de actualización de las reglas o bases de datos
- La Correlación de eventos como otros sistemas (SIEM, Antivirus, Firewalls,…)
- La Capacidad de aprendizaje en sistemas con IA o ML

- La Detección debe entenderse como un proceso continuo, sujeto a revisión, prueba y mejora constante. No existe una solución única válida para todas las organizaciones, sino que debe adaptarse a su tamaño, recursos y perfil de riesgo.

- **Tipos de Intrusiones:** Por objetivo, técnica, vector, momento de detección
- **Principales técnicas de detección**: Basada en firmas, basada en anomalías, enfoques híbridos
- **Ventajas de detección por firmas**: Precisión ante amenazas conocidas
- **Ventajas de detección por anomalías**: Detección de comportamientos inusuales o amenazas nuevas
- **Factores de eficiencia**: Ubicación, capacidad, actualización, correlación de eventos, aprendizaje.

Elementos funcionales comunes en Sistemas IDS/IPS

- Un IDS/IPS moderno es un Sistema Modular y evolutivo, diseñado para detectar, analizar y responder de manera inteligente a amenazas en entornos digitales.

- Componentes del Ecosistema IDS/IPS:
  1. **Motor de Análisis**: Motor de análisis esencial para la integración efectiva
  2. **Correlación de eventos**: Correlación de eventos mejora la integración con análisis avanzados
  3. **Captura de datos**: La Captura de datos es fundamental, pero con baja integración
  4. **Soporte para tráfico cifrado**: El Soporte para tráfico cifrado es avanzado, pero poco integrado.

Los Sistemas IDS/IPS comparten una **arquitectura modular** en la que distintos componentes colaboran para observar, analizar y reaccionar ante eventos de seguridad:

- **Captura o recolección de datos**
- **Normalización y preprocesamiento**
- **Motor de Análisis**
- **Gestor de alertas y acciones**
- **Interfaz de Gestión y Reporte**

- **Captura o recolección de datos:** Es el punto de entrada de toda la información que el Sistema debe analizar. Puede implicar la observación directa del tráfico de red o la monitorización de eventos y registros del SO.
- **Normalización y preprocesamiento:** Los datos recopilados pueden tener distintos formatos, niveles de ruido o redundancia. La normalización permite transformar esa información en una representación homogénea que pueda ser procesada. También se eliminan elementos irrelevantes, se reorganizan flujos y se ordenan cronológicamente los eventos.
- **Motor de Análisis:** En este paso se aplica la lógica de detección, ya sea mediante comparación con bases de firmas, detección de patrones anómalos, reglas heurísticas o análisis comparativos basados en IA. Este motor es el responsable de interpretar la actividad observada, identificar potenciales amenazas y asignarles un nivel de criticidad.

- **Gestor de alertas y acciones:** Una vez detectada una posible intrusión, el sistema debe tomar decisiones. En los IDS tradicionales, se traduce en una generación de alertas para el personal de seguridad. En los IPS, además, se pueden ejecutar acciones de forma automática como bloquear el tráfico, cerrar conexiones o aplicar filtros. El Gestor de alertas debe ser configurable, documentar todas las decisiones que se tomen, y permitir la trazabilidad.
- **Interfaz de Gestión y Reporte:** Todo Sistema IDS/IPS debe contar con una consola o panel de administración dese el que se visualicen los eventos, se configure el comportamiento del sistema, se generen informes y se integren otras soluciones como SIEM, Firewalls, antivirus o herramientas forenses. Una buena interfaz debe ser clara, segura, con capacidad de auditoría y soporte multicliente en entornos complejos.

Funcionalidades avanzadas integradas:

- **Correlación de eventos:** Consiste en la capacidad de relacionar eventos aparentemente aislados para detectar ataques distribuidos o progresivos.
- **Soporte para tráfico cifrado:** El auge del cifrado en las comunicaciones ha obligado a los sistemas IDS/IPS a implementar técnicas de inspección profunda del tráfico o a integrar sistemas proxy y balanceadores que permitan la inspección sin vulnerar la privacidad de los usuarios.
- **Inteligencia sobre amenazas:** Muchos Sistemas incorporan fuentes de inteligencia externas, lo que permite actualizar dinámicamente sus bases de detección para responder a amenazas (listas negras, firmas compartidas INCIBE, IOCs).
- **Integración con Sistemas de Respuesta automática:** En entornos de alta criticidad, el IDS/IPS puede formar parte de un ecosistema de respuesta orquestada, de modo que las alertas generen respuestas automáticas adaptadas al tipo de amenaza detectada: desconexión de dispositivos, contención de usuario, …

Indicadores de compromiso (IOCs): qué son y cómo identificarlos

2. Identificación y caracterización de los datos de funcionamiento del Sistema

2.1. Tipología de datos generados por el Sistema Informático

Clasificación general de los datos de funcionamiento

- En el contexto de la detección y prevención de intrusiones, es fundamental conocer con precisión qué tipo de datos genera un Sistema Informático durante sus operaciones habituales. Estos datos, correctamente caracterizados, constituyen la base para establecer patrones de comportamiento normal, detectar desviaciones, aplicar reglas de análisis y configurar mecanismos de alerta y respuesta.

Clasificación de los datos durante su funcionamiento:

- **Datos de Actividad del SO:** Incluye todos los eventos registrados por el SO en relación con procesos, servicios, acceso a archivos, cambios de configuración, utilización de recursos o fallos. Estos datos son almacenados en los registros o logs del sistema.
- **Datos de Tráfico de Red:** Información generada por la comunicación entre dispositivos, usuario y servicios a través de la red. Puede incluir encabezados de paquetes, protocolos, volumen de datos transmitidos, puertos implicados, duración de las sesiones, etc. Estos datos son fundamentales en los IDS/IPS basados en red.
- **Datos de Aplicación:** Son los Registros y Eventos generados por aplicaciones concretas: servidores web, gestores de BD, plataformas de correo electrónico, Sistemas ERP. Su análisis permite detectar vulnerabilidades explotadas a nivel de capa de aplicación.

Estructura y Formato de los datos

- Además de conocer la naturaleza de los datos, es esencial entender cómo se estructuran. El formato en que se presentan afecta directamente a la capacidad del sistema de detección para interpretarlo y analizarlos de forma eficaz.

Naturaleza de los datos:

- **Capacidad de discriminación:** Los datos útiles deben permitir diferenciar entre comportamiento legítimo y comportamiento sospechoso o malicioso. Nº de intentos de identificación fallidos, consumo excesivo de CPU en reposo,..
- **Correlación con otros eventos:** Un dato aislado puede no ser concluyente, pero si puede correlacionarse con otros se convierte en evidencia sólida de una posible intrusión.
- **Valor histórico y comparativo:** Los datos que permiten establecer una línea base de funcionamiento normal resultan extremadamente útiles ara detectar desviaciones significativas.

Relevancia operativa de los datos

- No todos los datos generados por el Sistema son relevantes para la detección de intrusiones. Una buena gestión de la información exige **seleccionar, clasificar y priorizar** aquellos datos que realmente aportan valor desde el punto de vista de la seguridad. Esto evita sobrecargar el sistema de análisis con información irrelevante o redundante.

Principales criterios para evaluar la relevancia de los datos:

- **Formato estructurado vs. no estructurado:** Los datos estructurados siguen un formato definido, lo que facilita su análisis automático, mientras que los no estructurados requieren técnicas de interpretación o análisis semántico.
- **Volatilidad de los datos:** Los datos que residen en memoria RAM son altamente volátiles y se pierden al reiniciar el sistema, mientras que otros pueden conservarse durante más tiempo.
- **Granularidad y nivel de detalle:** Dependiendo del sistema, y de su configuración, los datos pueden ser más o menos detallados. Un servidor web puede registrar solo resultados de peticiones http, o incluir detalles de usuarios, latencia, ubicación, …

Tipo de dato	Características principales	Uso IDS/IPS
Sistema Operativo	Logs de procesos, accesos, errores, cambios de configuración	Detección de actividad interna sospechosa
Tráfico de red	Paquetes, protocolos, IPs, Sesione	Análisis de flujos, escaneos, accesos no autorizados
Aplicaciones	Registros de errores, autenticaciones, operaciones específicas	Identificación de ataque a nivel de aplicación
Estructura de datos	Estructurados (json, csv) o no estructurados (texto libre)	Condiciona el análisis y la eficacia del Sistema
Relevancia	Capacidad de discriminación, correlación y valor histórico	Permite priorizar eventos y reducir falsos positivos

2.2. Extracción, almacenamiento y tratamiento de los datos de funcionamiento

Mecanismos de Extracción de Datos

Transformar datos brutos en Inteligencia de Seguridad requiere un ciclo integrado de extracción, almacenamiento y análisis especializado.

Ciclo Estratégico de Datos Operacionales:

- **Extracción de datos**
- **Almacenamiento de datos**
- **Procesamiento de datos**

Mecanismos de **Extracción de Datos**:

Este proceso se lleva a cabo mediante herramientas que permiten capturar, interceptar o suscribirse a las fuentes de información generadas por el Sistema Informático.

Mecanismos de Extracción, según el tipo de datos y el entorno:

- **Agentes locales o agents:** Son pequeños programas instalados en el Sistema que capturan información desde el SO, los logs de aplicaciones o el estado de los recursos. Funcionan en tiempo real o en intervalos programados, y pueden ser configurables según la necesidad de seguridad o el rendimiento esperado.
- **Sondas de red (networks probes):** Estas sondas se colocan en puntos estratégicos de la red para capturar el tráfico. Su finalidad es obtener una imagen completa del comportamiento de la red sin interferir en su funcionamiento.
- **Extracción basada en API o log shipping:** Muchas aplicaciones permiten extraer registros o eventos mediante interfaces que envían datos estructuras a sistemas externos para su análisis o almacenamiento.

Mecanismos de **Almacenamiento de Datos**:

Una vez extraídos, los datos deben almacenarse de forma eficiente, segura y conforme a la legislación (LOPD y Privacidad).

Factores Clave:

- **Formato de almacenamiento:**
  - **Logs planos**: registros en texto almacenado en ficheros secuenciales
  - **BD Relacionales**: permiten consultar grandes volúmenes de datos con estructuras conocidas
  - **BD NoSQL**: adecuadas para datos no estructurados, jerárquicos o distribuidos (MongoBD, Elasticsearch)
- **Criterios de conservación:** La duración del almacenamiento debe ajustarse a las políticas internas y a la normativa vigente.
- **Seguridad del almacenamiento:** Es esencial aplicar controles de acceso, cifrado en reposo, trazabilidad de consultas y sistemas de integridad para evitar manipulaciones.

Mecanismos de **Tratamiento y Análisis de Datos**:

Una vez almacenados, los datos deben ser tratados para extraer valor desde el punto de vista de la Seguridad. El tratamiento incluye limpieza, transformación, enriquecimiento y análisis e los datos.

Factores más importantes:

- **Normalización y estructuración:** Consiste en transformar los datos heterogéneos en un formato común que permita su análisis.
- **Correlación de eventos:** Se identifican relaciones entre distintos datos que, individualmente, no supondrían un riesgo, pero que en su conjunto evidencian una posible amenaza.
- **Enriquecimiento contextual:** Consiste en añadir información adicional para mejorar la capacidad de decisión de los sistemas automáticos y técnico.
- **Clasificación y priorización**: Una vez tratados, los eventos se clasifican por criticidad, tipo, origen o sistema afectado. Esta clasificación permite establecer alertas, escalado y asignación de recursos para la respuesta ante incidentes.

FASE	Descripción	Herramientas comunes
Extracción	Captura de eventos desde el SO, red o aplicaciones	Agendes, sondas, webhooks, APIs
Almacenamiento	Registro seguro de eventos en formatos estructurados o no estructurados	BD, logs, soluciones cloud
Tratamiento	Limpieza, correlación y enriquecimiento para análisis y priorización de amenazas	SIEM, reglas de correlación, motores de IA
Normalización	Unificación de formatos para facilitar el análisis transversal	Parsers, sistemas de categorización
Enriquecimiento	Añadir contexto a los eventos (reputación, geolocalización, rol de usuario)	Threat feeds, herramientas OSINT, BD

¿Qué es la extracción de datos? Definición, cómo funciona y técnicas

3. Arquitecturas más frecuentes de los Sistemas de Detección de Intrusos

Modelos de IDS/IPS en red y host

La arquitectura de los sistemas IDS/IPS pude adaptarse tanto a la supervisión del tráfico de red como al monitoreo interno de los equipos.

Componentes de los Sistemas de Seguridad de Red:

- **IDS/IPS basados en Host:** Supervisan el comportamiento interno del Sistema Operativo para detectar anomalías
- **IDS/IPS basados en Red:** Supervisan el tráfico de red en tiempo real para detectar intrusiones

IDS/IPS basados en red (Network-based IDS/IPS)

Los sistemas IDS/IPS basados en red se diseñan para supervisar y analizar el tráfico de red en tiempo real, con el fin de detectar posibles intrusiones o comportamientos anómalos. Se colocan en puntos estratégicos de la infraestructura de comunicaciones para interceptar paquetes de datos, sin interferir en la operación normal.

Funcionamiento: Estos sistemas analizan el contenido de los paquetes que circulan por la red, así como sus encabezados, protocolos y flujos. El análisis puede ser superficial (por encabezados) o profundo (Deep packet inspection) para identificar amenazas ocultas dentro del propio contenido. En función de si solo detectan o también bloquean tráfico, se clasifican como NIDS (detección) o NIPS (prevención)

Ventajas

- No requieren instalación en cada equipo
- Permiten una visión global del tráfico de red
- Detectan ataques dirigidos a varios equipos simultáneamente

Limitaciones

- No monitorizan eventos internos del SO o de aplicaciones locales
- Pueden verse limitados por el uso de cifrado
- Requieren alta capacidad de procesamiento para analizar grandes volúmenes de tráfico

IDS/IPS basados en Host (Host-based IDS/IPS)

Los sistemas IDS/IPS basados en host se instalan directamente en los equipos a proteger. Supervisan el comportamiento interno del Sistema Operativo, los registros de actividad y los procesos en ejecución, lo que les permite detectar anomalías específicas del entorno local.

Funcionamiento: Capturan eventos del Sistema, como accesos a archivos críticos, cambios en el registro, ejecuciones de procesos, alteraciones en servicios o modificaciones de configuración. Pueden analizar los logs, interceptar llamadas al Sistema, o emplear técnicas de control de integridad.

Ventajas

- Detectan amenazas que no generan tráfico de red, como accesos indebidos a archivos o uso de privilegios elevados
- Son útiles en entornos donde el cifrado impide el análisis de red
- Permiten establecer reglas muy personalizadas por equipo o aplicación.

Limitaciones

- Requieren instalación, mantenimiento y recursos en cada equipo
- Pueden ser desactivados o manipulados por malware si no están protegidos adecuadamente
- No ofrecen visión global del entorno de red

IDS/IPS basados en Red y en Host

Ambos modelos presentan ventajas e inconvenientes, por lo que la mayoría de las arquitecturas profesionales combinan sistemas de detección en red y en host para lograr una cobertura integral, especialmente en entornos donde la seguridad es crítica.

En el Diseño de una Arquitectura de Seguridad, debemos de tener en cuenta:

- El número y tipo de dispositivos a proteger
- La sensibilidad de los datos manejados
- Las Políticas de Cifrado en las comunicaciones
- La Disponibilidad de personal y recursos técnicos para el mantenimiento y respuesta.

7 tipos de sistemas de detección de intrusos que detectan anomalías en la red

Sistemas Híbridos y Distribuidos en entornos corporativos

Los Sistemas híbridos y distribuidos combinan enfoques de red, host y análisis centralizado, permitiendo una defensa integrada y escalable en entornos corporativos complejos.

- **Sistemas híbridos de Detección y Prevención:** Los Sistemas híbridos integran funciones de detección y prevención tanto a nivel de red como en lo equipos finales. Puede estar compuesto por varias soluciones coordinadas entre sí, o bien por plataformas unificadas que ofrecen agentes para host y sensores de red centralizados.

Sistemas híbridos de Detección y Prevención

En los entornos profesionales, los Sistemas IDS/IPS son suelen limitarse a una única modalidad (en red o host), sino que combinan ambos enfoques para lograr una protección más completa.

- Un Sistema Híbrido **integra funciones de detección y prevención tanto a nivel de red como en los equipos finales**. Puede estar compuesto por varias soluciones coordinadas entre sí, o bien por plataformas unificadas que ofrecen agentes para host y sensores de red centralizados.

Sistemas Distribuidos y Escalabilidad

Los Sistemas IDS/IPS deben poder funcionar de forma distribuida para abarcar múltiples ubicaciones, centros de datos, sedes o segmentos de red. La arquitectura distribuida garantiza escalabilidad, disponibilidad y una supervisión más precisa.

Elementos distribuidos clave:

- Sensores: capturan eventos locales y los envían a analizar
- Agentes: Instalados en los dispositivos finales para recoger y filtrar los datos
- Nodos de análisis: Pueden estar centralizados o replicados para permitir el procesamiento local o global
- Consola unificada: Permite administrar todo el Sistema desde una única interfaz, con políticas segmentadas por zona.

Beneficios operativos

- Reducción de la latencia y del tráfico de red, al analizar los datos de origen
- Tolerancia a fallos: si un nodo falla, el resto sigue funcionando
- Mayor granularidad: posibilidad de aplicar políticas específicas independientes

Desafíos asociados

- Complejidad en la configuración y mantenimiento
- Necesidad de sincronización de reglas, firmas y datos entre nodos
- Riego de silos informativos si no se articula una estrategia clara de correlación y compartición de eventos.

Coordinación y Orquestación de Sistemas Híbridos

La Orquestación implica la Gestión centralizada de las políticas, la correlación de eventos y la activación de respuestas automáticas.

Las soluciones **SOAR** (Security Orchestration, Automation and Response) permiten automatizar flujos de trabajo de seguridad, integrar múltiples sistemas de detección y respuesta, y aplicar reglas de actuación homogéneas.

Ventajas de la Orquestación:

- Mejora la capacidad de respuesta ante incidentes complejos o simultáneos
- Reduce la carga de trabajo manual en los equipos SOC
- Aumenta la coherencia y la trazabilidad de las decisiones adoptadas

Tipo de Sistema	Características principales	Ventajas operativas	Riesgos o desafíos
Híbrido	Combina detección en red y host	Visión completa del entorno	Mayor complejidad técnica
Distribuido	Dispersión de sensores y nodos en varias ubicaciones	Escalabilidad, tolerancia a fallos	Coordinación, riesgo de silos informativos
Orquestado (SOAR)	Automatización de respuestas y coordinación de múltiples herramientas	Respuesta rápida y coherente	Coste, necesidad de procesos bien definidos

SOAR de Nueva Generación con IA: redefiniendo la orquestación de la Ciberseguridad

4. Relación de los distintos tipos de IDS/IPS por ubicación y funcionalidad

Clasificación de IDS/IPS según su ubicación en la arquitectura de red

Factores que determinan la ubicación del IDS/IPS

La ubicación física o lógica de un IDS/IPS dentro de la arquitectura de red es un factor decisivo para su eficacia. No todos los puntos de una red presentan el mismo nivel de exposición, criticidad o volumen de tráfico.

La elección de la ubicación debe basarse en criterios como:

- Objetivos de Detección o Prevención: ¿Se desea proteger la red frente a accesos externos?¿Se quiere vigilar el comportamiento interno de dispositivos críticos? ¿Es necesario controlar el tráfico entre segmentos de red?
- Topología de red: Redes planas frente a redes segmentadas. Existencia de DMZ, VLAN, VPN,…Presencia de Firewalls, o Gateways
- Volumen y tipo de tráfico esperado: Ubicar un IDS en un punto de la red con tráfico excesivo puede saturarlo, mientras que una ubicación con poco tráfico puede no ofrecer información útil.

Qué es una DMZ y cómo te puede ayudar a proteger tu empresa

Tipos de IDS/IPS según ubicación

Podemos clasificar los Sistemas IDS/IPS en función de su posición relativa dentro de la infraestructura:

- Perimetrales
- DMZ
- Internos
- En puntos de acceso inalámbricos
- Distribuidos por VLAN o Segmentos Virtualizados

Perimetrales:

- Se colocan en el punto de entrada o salida de la red corporativa, habitualmente detrás del firewall y antes de la red interna.
- Permiten detectar ataques externos y escaneos desde Internet
- Suelen ser NIDS/NIPS de alto rendimiento
- Requieren alta disponibilidad y capacidad de filtrado rápido

En zonas desmilitarizadas (DMZ):

- La DMZ aloja servidores expuestos al exterior (web, correo, DNS, …)
- Colocar un IDS/IPS en esta zona permite controlar posibles ataques dirigidos a estos servicios
- Ayudan a detectar intentos de explotación de vulnerabilidades
- Son útiles para registrar patrones de ataque persistentes

Internos (Intra-red):

- Se ubican en segmentos internos de la red, como subredes de usuarios, servidores o áreas de administración
- Detectan movimientos laterales, amenazas internas o actividades anómalas
- Son especialmente relevantes para prevenir ataques de tipo insider o propagación de malware

En Puntos de Acceso Inalámbricos (IDS inalámbricos):

- Vigilan el tráfico generado por dispositivos conectados a redes Wifi
- Son útiles para identificar accesos no autorizados, suplantación de puntos de acceso (rogue AP) o ataques como deauthentication o man-in-the-middle.

Distribuidos por VLAN o segmentos virtualizados

- En entornos virtualizados, el IDS/IPS puede ubicarse en hipervisores o en redes definidas por software (SDN), monitorizando el tráfico entre máquinas virtuales que no necesariamente pasa por la infraestructura física.

Consideraciones especiales en redes modernas

La evolución de las redes hacia modelos más dinámicos y virtualizados ha hecho necesario adaptar la ubicación de los IDS/IPS.

- Redes definidas por software (SDN): Los IDS/IPS deben integrarse con los controladores SDN para recibir copia del tráfico y aplicar políticas de seguridad dinámicas
- Entorno en la nube (cloud): Las soluciones IDS/IPS se los servidores en la nube deben desplegarse como instancias virtuales o integrarse como servicios, ya que no es posible integrar sondas físicas.
- IoT y redes industriales: Se requieren sensores IDS/IPS especializados que comprendan protocolos industriales y puedan detectar alteraciones sin afectar la producción

Ubicación	Función Principal	Ventajas	Limitaciones
Perimetrales	Monitorizan tráfico E/S	Detectan ataques externos, escaneos	No observan actividad interna
En DMZ	Protegen servicios expuestos al exterior	Detectan intentos de explotación de servicios públicos	Visión limitada a los servicios alojados
Internos	Vigilan tráfico entre dispositivos locales	Detectan movimientos laterales y amenazas internas	Requieren segmentación lógica y sensores adicionales
Inalámbricos	Monitorizan redes Wifi y dispositivos móviles	Detectan accesos no autorizados y ataques específicos	Menor cobertura de dispositivos cableados
Virtualizados/ SDN	Analizan tráfico entre máquinas virtuales y redes definidas por software	Adaptados a entornos dinámicos	Requieren integración con hipervisores o SDN

Clasificación funcional de los Sistemas IDS/IPS

Criterios de Clasificación Funcional

Desde el punto de vista funcional, los IDS/IPS pueden clasificarse en función de qué tipo de análisis realizar y cómo responden a las amenazas detectadas.

- **Tipo de detección utilizada**:
  - Por firmas: comparan los datos observados con patrones conocidos de ataque
  - Por anomalías: detectan desviaciones respecto al comportamiento habitual
  - Heurística: aplican reglas empíricas o análisis de comportamiento sin una firma explícita
  - Híbrida: combinan varios mecanismos de detección para aumentar la cobertura y precisión
- **Capacidad de respuesta**
  - IDS: Se limitan a detectar y generar alertas.
  - IPS: Previenen activamente las intrusiones mediante acciones automáticas
- **Nivel de Inteligencia Artificial aplicada**
  - Estadísticos: utilizan reglas o firmas fijas, con baja adaptabilidad.
  - Dinámicos: Incorporan capacidades de ML para mejorar el análisis en función del comportamiento observado.

Principales Tipos Funcionales de IDS/IPS

- **IDS Pasivos:** Detectan intrusiones, pero no actúan directamente sobre el entorno. Se utilizan para monitorización, análisis forense y auditoría.
- **IPS Activos:** Actúan en tiempo real para evitar que el ataque tenga éxito. Pueden cerrar conexiones, modificar rutas o bloquear direcciones IP.
- **Sistemas basados en Comportamiento:** Aprenden el funcionamiento habitual del Sistema y detectan desviaciones, incluso si no existe una firma conocida.
- **Sistemas Correlacionados:** No analiza únicamente eventos aislados, sino que relacionan múltiples señales de diferentes fuentes para generar alerta más precisas. Suelen integrarse en sistemas SIEM o SOAR.
- **Sistemas específicos para tipos concretos de amenazas:** Algunas soluciones están diseñadas para amenazas particulares, como sistemas de detección de botnets, ataques de denegación de servicio, filtrado de contenido o detección de ransomware.

Elección funcional según necesidades de Seguridad

La selección de un tipo de DIS/IPS debe basarse en un análisis de riesgos, recursos disponibles y perfil de amenazas.

Recomendaciones:

- **IDS pasivos**: Adecuados para entornos donde se prioriza el análisis forense, la monitorización sin impacto o la auditoría histórica
- **IPS activos**: Imprescindibles en infraestructuras críticas, entornos industriales, financieros o sanitarios donde la contención inmediata es clave.
- **Sistemas híbridos y basados en comportamiento**: Recomendables en organizaciones con infraestructuras dinámicas, usuarios diversos o elevado volumen de tráfico.
- **Sistemas específicos**: Muy útiles cuando existe una amenaza concreta identificada, como riesgo de filtraciones de información, campañas de phishing o ataques internos.

5. Criterios de Seguridad para el establecimiento de la ubicación de los IDS/IPS

Factores técnicos y organizativos en la ubicación del IDS/IPS

Factores técnicos que influyen en la ubicación

Existen factores técnicos determinantes que condicionan el rendimiento, la capacidad de detección y la fiabilidad de los Sistemas. La adecuada disposición de sensores y dispositivos de prevención es clave para garantizar una cobertura eficaz sin generar cuellos de botella ni puntos ciegos.

Factores técnicos:

- **Topología de red**
- **Velocidad y volumen de tráfico**
- **Cifrado de comunicaciones**
- **Latencia y disponibilidad**

- **Topología de red:** El diseño físico y lógico de la red condiciona dónde se puede ubicar un Sistema IDS/IPS. En redes segmentadas, distribuidas o definidas por Software, es imprescindible colocar sensores en cada segmento relevante. En redes planas, basta con ubicaciones estratégicas en puntos de agregación o paso forzado del tráfico.
- **Velocidad y volumen de tráfico:** En entornos de alta velocidad, es necesario contar con dispositivos de alto rendimiento o aplicar filtrado previo. Si no se dimensiona correctamente, puede haber pérdida de paquetes o fallos de detección.
- **Cifrado de comunicaciones:** El uso generalizado de protocolos cifrados impide que muchos IDS/IPS inspeccionen el contenido del tráfico.
- **Latencia y disponibilidad:** En los IPS activos es fundamental que la ubicación no introduzca retardo excesivo en la comunicación. Además, deben desplegarse en alta disponibilidad para evitar que su fallo afecte a la continuidad del servicio.

Factores organizativos a considerar

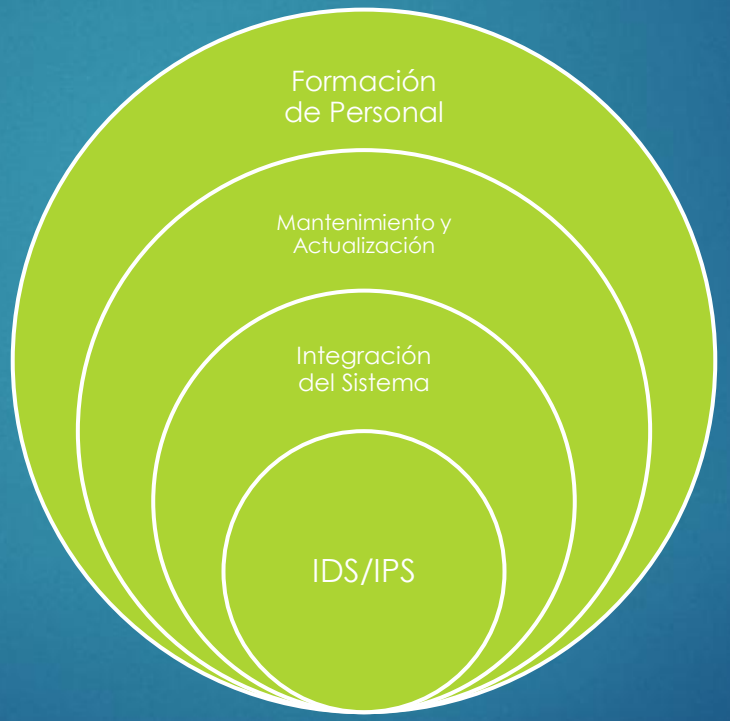
Además de las cuestiones técnicas, existen factores organizativos y estratégicos que deben tenerse en cuenta a l la hora de ubicarlo. Estos factores están ligados a la estructura interna, las prioridades del negocio y el cumplimiento normativo.

- **Clasificación de activos:** No todos los sistemas y servicios tienen el mismo nivel de criticidad. Es prioritario proteger aquellos que procesan datos sensibles, soportan operaciones críticas de la organización o son más vulnerables.
- **Perfil de amenazas y análisis de riesgos:** El historial de incidentes, los informes de amenazas más probables y las características del entorno nos obligan a priorizar ubicaciones.
- **Disponibilidad de personal y recursos:** El personal técnico necesita poder acceder a los dispositivos, ya sea físicamente o a través de interfaces remotas.
- **Cumplimiento normativo:** ENS (Esquema Nacional de Seguridad), RGPD, LOPDGDD, ISO 27000 o NIS2

Buenas prácticas para la integración efectiva de IDS/IPS

Una interfaz eficaz de IDS/IPS combina tecnología, mantenimiento y formación para lograr una protección realmente efectiva.

:



Marco de Gestión de Sistemas de Detección de Intrusiones

Integración con otros sistemas de seguridad

Los IDS/IPS no deben de funcionar de forma aislada, sino como elementos coordinados dentro de un sistema más amplio de protección, detección y respuesta.

Principales integraciones recomendadas:

- **Sistemas de Gestión de Eventos e Información de Seguridad (SIEM):** Permite centralizar los eventos generados, correlacionarlos con otros datos y aplicar reglas para generar alertas más precisas.
- **Plataformas de orquestación y automatización (SOAR):** Facilitan la respuesta automatizada ante incidentes detectados, incluyendo bloqueos, notificaciones o generación de informes.
- **Cortafuegos y Sistemas de Control de Acceso:** Un IDS puede actuar como fuente de información para modificar dinámicamente reglas de un firewall. Un IPS puede trabajar en conjunción con estos para ampliar las capacidades de inspección y contención.
- **Sistemas de Gestión de Identidades (IAM):** En entornos sensibles, los IDS/IPS pueden integrarse con el sistema de identidades para asociar eventos a usuarios específicos, restringir cuentas comprometidas o ajustar privilegios ante actividad anómala.

Revisión y mantenimiento continuo del sistema IDS/IPS

Un error frecuente es considerar el IDS/IPS como un Sistema estático. La eficacia de estos dispositivos depende de una supervisión y actualización constantes.

Buenas prácticas:

- **Actualización regular de firmas y reglas** Los sistemas basados en firmas deben disponer de mecanismos automáticos y seguros para descargar nuevas reglas.
- **Ajuste fino de umbrales y parámetros:** Es esencial revisar periódicamente los umbrales aleta en función de la experiencia acumulada y la evolución del entorno para evitar falsos positivos.
- **Pruebas periódicas y simulaciones de intrusión:** Simular pruebas de intrusión permite comprobar si el sistema responde correctamente. Estas pruebas deben realizarse de forma controlada y con autorización previa.
- **Auditorías y análisis de eficacia:** Es recomendable establecer métricas de evaluación, tasa de detección, número de alertas útiles y falsas, tiempos de respuesta, …

Formación del personal y cultura de seguridad

La integración efectiva de un IDS/IPS requiere personal formado y una cultura de seguridad activa.

La implicación del personal es clave para interpretar correctamente las alertas, priorizar respuestas y mantener actualizado el Sistema.

Los administradores del Sistema deben conocer el funcionamiento del IDS/IPS, saber interpretar los eventos, gestionar falsos positivos, y aplicar respuestas adecuadas.

Cada alerta debe estar asociada a un procedimiento claro: cómo escalar, a quién notificar, qué medidas tomar, qué documentación generar.

Un Sistema de detección puede generar alertas sobre usuarios internos. Es importante que exista un clima de confianza, responsabilidad y transparencia que permita actuar.